

Security+ 4.8 · Incident Planning

Mestre CyberSec — Guia Completo CompTIA Security+ (SY0-701) · **Aula 4.8 — Incident Planning (6:50)** · [Vídeo no YouTube ↗](#)

Resumo da Aula: Tabletop exercise (jogo fictício — treina decisores); simulation (falta simulada); RCA (root cause analysis — o porquê real); documentation; playbook por tipo (ransomware/phishing).

Highlights que a prova cobra

- Tabletop: o 'jogo de mesa' do incidente — treina sem impacto real
- RCA: a causa RAIZ (o porquê), não o sintoma

Dicas de prova & Cenários Típicos

- 'simulated exercise without real impact'=tabletop

Cenário clássico de exame: 'empresa joga o cenário de ransomware em conversa pra testar resposta'=tabletop.

 **Além do Vídeo: O que a CompTIA cobra na prova (Conceitos, Siglas e**

Armadilhas da Seção 4.8)

Por que este aprofundamento é cobrado no exame? O vídeo do Professor Messer (Incident Planning) resume os conceitos de forma ágil. Contudo, a banca examinadora oficial da CompTIA (SY0-701) exige raciocínio prático de engenharia de segurança, diferenciação entre protocolos concorrentes e aplicação em cenários corporativos reais. Entenda os conceitos complementares fundamentais:

- **Monitoramento de Segurança (SIEM, SOAR, EDR/XDR):**
 - **SIEM:** centraliza, normaliza e correlaciona eventos de logs em tempo real para disparar alertas de segurança.
 - **SOAR:** automatiza respostas a incidentes através de playbooks coordenados, reduzindo o tempo de reação humano.
 - **EDR/XDR:** detecção e resposta a anomalias no endpoint (EDR) estendida a e-mail, nuvem e identidades (XDR).
- **Fases da Resposta a Incidentes (NIST SP 800-61 / PICERL):**
 1. **Preparação:** políticas, ferramentas, treinamentos.
 2. **Identificação/Detecção:** triagem de alertas e confirmação do incidente.
 3. **Contenção:** isolamento do sistema afetado para impedir propagação (sem destruir provas).
 4. **Erradicação:** remoção de malwares, fechamento de brechas e contas comprometidas.
 5. **Recuperação:** restauração segura dos serviços a partir de backups limpos e validação de produção.
 6. **Lições Aprendidas:** reunião pós-incidente e melhorias nos playbooks.
- **Forense Digital e Ordem de Volatilidade (RFC 3227):** Durante a coleta de evidências forenses, os artefatos mais voláteis (que somem ao desligar) devem ser capturados primeiro:
 1. Registradores da CPU e memória Cache.
 2. Memória RAM (volátil: contém senhas em claro, chaves criptográficas em uso e conexões ativas).
 3. Estado das conexões de rede e processos em execução.
 4. Sistema de arquivos e discos rígidos (HD/SSD).
 5. Mídias ópticas e backups externos arquivados.

⚠ **Armadilhas e Pegadinhas Clássicas da Banca:**

- NUNCA desligue ou reinicie um servidor comprometido antes de realizar o dump forense da memória RAM; reiniciar destrói evidências essenciais de malwares fileless.
- Qualquer manipulação de evidência digital exige cálculo imediato de hash (SHA-256) e registro rigoroso da Cadeia de Custódia (Chain of Custody).

✓ Perguntas de treino comentadas (10 questões)

Gabarito com resolução passo a passo e análise dos distratores no fim. Tente responder antes de olhar.

1. De acordo com o NIST, qual é a primeira fase do ciclo de resposta a incidentes?

- A)** Detecção e Análise
- B)** Preparação
- C)** Contenção
- D)** Recuperação

2. Cenário corporativo (Incident Planning): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 4.8), um analista avalia o seguinte requisito técnico: 'Tabletop: o 'jogo de mesa' do incidente — treina sem impacto real'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Permitir acesso compartilhado entre administradores com credenciais genéricas
- D)** Implementar a solução correspondente: Tabletop: o 'jogo de mesa' do incidente — treina sem impacto real...

3. Cenário corporativo (Incident Planning): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 4.8), um analista avalia o seguinte requisito técnico: 'RCA: a causa RAIZ (o porquê), não o sintoma'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Implementar a solução correspondente: RCA: a causa RAIZ (o porquê), não o sintoma...
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

4. Cenário corporativo (Incident Planning): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 4.8), um analista avalia o seguinte requisito técnico: "simulated exercise without real impact'=tabletop'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Implementar a solução correspondente: 'simulated exercise without real impact'=tabletop...
- B)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

5. Cenário corporativo (Incident Planning): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 4.8), um analista avalia o seguinte requisito técnico: "empresa joga o cenário de ransomware em conversa pra testar resposta'=tabletop.'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Implementar a solução correspondente: 'empresa joga o cenário de ransomware em conversa pra testar resposta'=tabl...
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

6. Cenário corporativo (Incident Planning): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 4.8), um analista avalia o seguinte requisito técnico: 'Tabletop: o 'jogo de mesa' do incidente — treina sem impacto real'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Implementar a solução correspondente: Tabletop: o 'jogo de mesa' do incidente — treina sem impacto real...
- B)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

7. Cenário corporativo (Incident Planning): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 4.8), um analista avalia o seguinte requisito técnico: 'RCA: a causa RAIZ (o porquê), não o sintoma'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Implementar a solução correspondente: RCA: a causa RAIZ (o porquê), não o sintoma...
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

8. Cenário corporativo (Incident Planning): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 4.8), um analista avalia o seguinte requisito técnico: 'simulated exercise without real impact'=tabletop'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Implementar a solução correspondente: 'simulated exercise without real impact'=tabletop...
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

9. Cenário corporativo (Incident Planning): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 4.8), um analista avalia o seguinte requisito técnico: 'empresa joga o cenário de ransomware em conversa pra testar resposta'=tabletop.'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Implementar a solução correspondente: 'empresa joga o cenário de ransomware em conversa pra testar resposta'=tabl...
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

10. Cenário corporativo (Incident Planning): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 4.8), um analista avalia o seguinte requisito técnico: 'Tabletop: o 'jogo de mesa' do incidente — treina sem impacto real'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Implementar a solução correspondente: Tabletop: o 'jogo de mesa' do incidente — treina sem impacto real...
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

GABARITO COMENTADO COM ANÁLISE DE DISTRATORES

1) B — Preparação.

✓ **Por que está certa:** O framework NIST de resposta a incidentes tem 4 fases: Preparação, Detecção e Análise, Contenção/Erradicação/Recuperação, e Atividades Pós-Incidente. Preparação é a primeira.

✗ **Por que as outras estão erradas:**

- *Detecção e Análise:* Não atende ao requisito técnico apresentado no cenário, contrariando as boas práticas e controles exigidos pelo exame CompTIA Security+.
- *Contenção:* Não atende ao requisito técnico apresentado no cenário, contrariando as boas práticas e controles exigidos pelo exame CompTIA Security+.
- *Recuperação:* Não atende ao requisito técnico apresentado no cenário, contrariando as boas práticas e controles exigidos pelo exame CompTIA Security+.

2) D — Implementar a solução correspondente: Tabletop: o 'jogo de mesa' do incidente — treina sem impacto real....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 4.8 (Incident Planning): Tabletop: o 'jogo de mesa' do incidente — treina sem impacto real.

✗ **Por que as outras estão erradas:**

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destrói a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

3) B — Implementar a solução correspondente: RCA: a causa RAIZ (o porquê), não o sintoma....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 4.8 (Incident Planning): RCA: a causa RAIZ (o porquê), não o sintoma.

✗ **Por que as outras estão erradas:**

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destrói a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

4) A — Implementar a solução correspondente: 'simulated exercise without real impact' = tabletop....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701)

para a aula 4.8 (Incident Planning): 'simulated exercise without real impact'=tabletop.

✗ Por que as outras estão erradas:

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destrói a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

5) B — Implementar a solução correspondente: 'empresa joga o cenário de ransomware em conversa pra testar resposta'=tabl....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 4.8 (Incident Planning): 'empresa joga o cenário de ransomware em conversa pra testar resposta'=tabletop..

✗ Por que as outras estão erradas:

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destrói a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

6) A — Implementar a solução correspondente: Tabletop: o 'jogo de mesa' do incidente — treina sem impacto real....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 4.8 (Incident Planning): Tabletop: o 'jogo de mesa' do incidente — treina sem impacto real.

✗ Por que as outras estão erradas:

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destrói a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

7) B — Implementar a solução correspondente: RCA: a causa RAIZ (o porquê), não o sintoma....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 4.8 (Incident Planning): RCA: a causa RAIZ (o porquê), não o sintoma.

✗ Por que as outras estão erradas:

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destrói a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

8) C — Implementar a solução correspondente: 'simulated exercise without real impact' = tabletop....

- ✓ Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 4.8 (Incident Planning): 'simulated exercise without real impact' = tabletop.

✗ Por que as outras estão erradas:

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destrói a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

9) B — Implementar a solução correspondente: 'empresa joga o cenário de ransomware em conversa pra testar resposta' = tabl....

- ✓ Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 4.8 (Incident Planning): 'empresa joga o cenário de ransomware em conversa pra testar resposta' = tabletop..

✗ Por que as outras estão erradas:

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destrói a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

10) C — Implementar a solução correspondente: Tabletop: o 'jogo de mesa' do incidente — treina sem impacto real....

- ✓ Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 4.8 (Incident Planning): Tabletop: o 'jogo de mesa' do incidente — treina sem impacto real.

✗ Por que as outras estão erradas:

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destrói a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.